

Informe Técnico

Nombre: Vejat Olea

Fecha: Julio 2026

1. Descripción

SecureUpdate Keylogger es un implante de espionaje para Windows 11 que captura pulsaciones de teclado, las almacena en memoria, las cifra con AES-256-GCM y las exfiltra cada 20 segundos hacia un servidor Flask controlado por el atacante. Se ejecuta sin ventana visible y persiste tras reinicio mediante el registro de Windows.

Se desarrolló en Python y se distribuye compilado como `WindowsSecurityUpdateService.exe` con PyInstaller, usando un nombre que imita una actualización legítima del sistema.

2. Vector de infección y objetivo

El sistema operativo objetivo es Windows 11 de 64 bits. En el laboratorio, el vector fue la ejecución manual del binario en la VM víctima, simulando un usuario que abre un archivo disfrazado de actualización de seguridad.

El implante no requiere privilegios de administrador. Solo necesita acceso de red hacia el servidor receptor y puede correr como script Python o como binario standalone. Al ejecutarse, se auto-registra en `HKCU\Software\Microsoft\Windows\CurrentVersion\Run` bajo el nombre `WindowsSecurityUpdateService`, apuntando a `run_keylogger.bat`.

Objetivo del atacante: obtener de forma sigilosa el contenido escrito por el usuario (credenciales, mensajes y datos sensibles) y exfiltrarlo de manera periódica al servidor de mando y control.

3. TTPs según MITRE ATT&CK

Ejecución (T1204.002): el usuario ejecuta el `.exe` o `.bat` malicioso.

Ejecución (T1059.006): el implante corre sobre intérprete Python (`pythonw.exe`) o como binario empaquetado.

Persistencia (T1547.001): entrada en el registro Run de HKCU y copia en la carpeta Startup del usuario.

Evasión (T1036.005, T1027, T1027.002): nombre `WindowsSecurityUpdateService` para parecer legítimo; binario empaquetado con PyInstaller onefile sin ventana de consola.

Recolección (T1056.001): captura de teclado con hook de `pynput`.

Comando y control (T1071.001): exfiltración vía HTTP POST con JSON al endpoint `/upload`.

Exfiltración (T1041): envío cifrado periódico cada 20 segundos al servidor Flask.

Cifrado (T1573.001): el contenido sensible viaja cifrado con AES-256-GCM (clave simétrica en `secret.key`); el tráfico HTTP solo expone metadatos y el `payload` en base64.

4. Indicadores de compromiso (IoCs)

Archivos: `WindowsSecurityUpdateService.exe` (~14,4 MB), `run_keylogger.bat`, `secret.key`.

Registro: `HKCU\Software\Microsoft\Windows\CurrentVersion\Run` → `WindowsSecurityUpdateService`.

Startup: `%APPDATA%\Microsoft\Windows\Start Menu\Programs\Startup` (copia de respaldo del launcher).

Red: origen `192.168.56.107` (víctima) → destino `http://192.168.56.108:5000/upload` (C2), POST periódico cada 20 s, payload JSON en base64.

Hashes:

```
MD5:      d898a74518d707f35446b2aecf39133b
SHA-1:    18139dd3c3d2184707f878929d5f466ad617244b
SHA-256:  7CEFCF86B89F2323E5279BF7D24D5BD424F4A52A6E831FE6CD6FDBF838E5F421
```

VirusTotal: 19/69 detecciones (27,5%), etiqueta `trojan.clyp/keylogger`.

Enlace:

<https://www.virustotal.com/gui/file/7cefcf86b89f2323e5279bf7d24d5bd424f4a52a6e831fe6cd6fdbf838e5f421>

Detecciones relevantes: ESET `Python/Spy.KeyLogger.MT`, Kaspersky `HEUR:Trojan-Spy.Python.Keylogger.ae`, Yandex `Riskware.PyInstaller`.

Proceso: `pythonw.exe` (script) o `WindowsSecurityUpdateService.exe` (compilado), sin ventana visible.

5. Impacto potencial

Permite robo de credenciales escritas en aplicaciones no protegidas, captura de conversaciones y contenido sensible, y persistencia tras reinicio. El tráfico cifrado dificulta la inspección pasiva de red. No captura de forma fiable campos de contraseña en navegadores modernos ni actividad en sesiones elevadas con UAC.

6. Recomendaciones de mitigación

Monitorear cambios en claves Run de HKCU y HKLM, y revisar la carpeta Startup con herramientas como Autoruns o Process Explorer. Alertar sobre procesos sin ventana con conexiones HTTP periódicas salientes. En red, usar Wireshark, Zeek o un IDS para detectar POST a `/upload` con payloads base64 grandes. Incluir el hash del ejecutable en listas de bloqueo. Usar Application Control para binarios no firmados, segmentar la red para limitar comunicación con el C2, y mantener EDR activo.

Ante un incidente: aislar el host, limpiar registro y Startup, eliminar el ejecutable y `secret.key`, y rotar credenciales del equipo afectado. Los usuarios deben evitar ejecutar archivos desconocidos y preferir gestores de contraseñas con protección anti-keylogging.

7. Conclusión

SecureUpdate Keylogger es una amenaza de espionaje de baja complejidad pero efectiva en entornos sin controles de detección. Combina persistencia en registro, ejecución oculta y cifrado de exfiltración. Las defensas más efectivas combinan monitoreo de autostart, EDR, análisis de tráfico y concienciación del usuario.